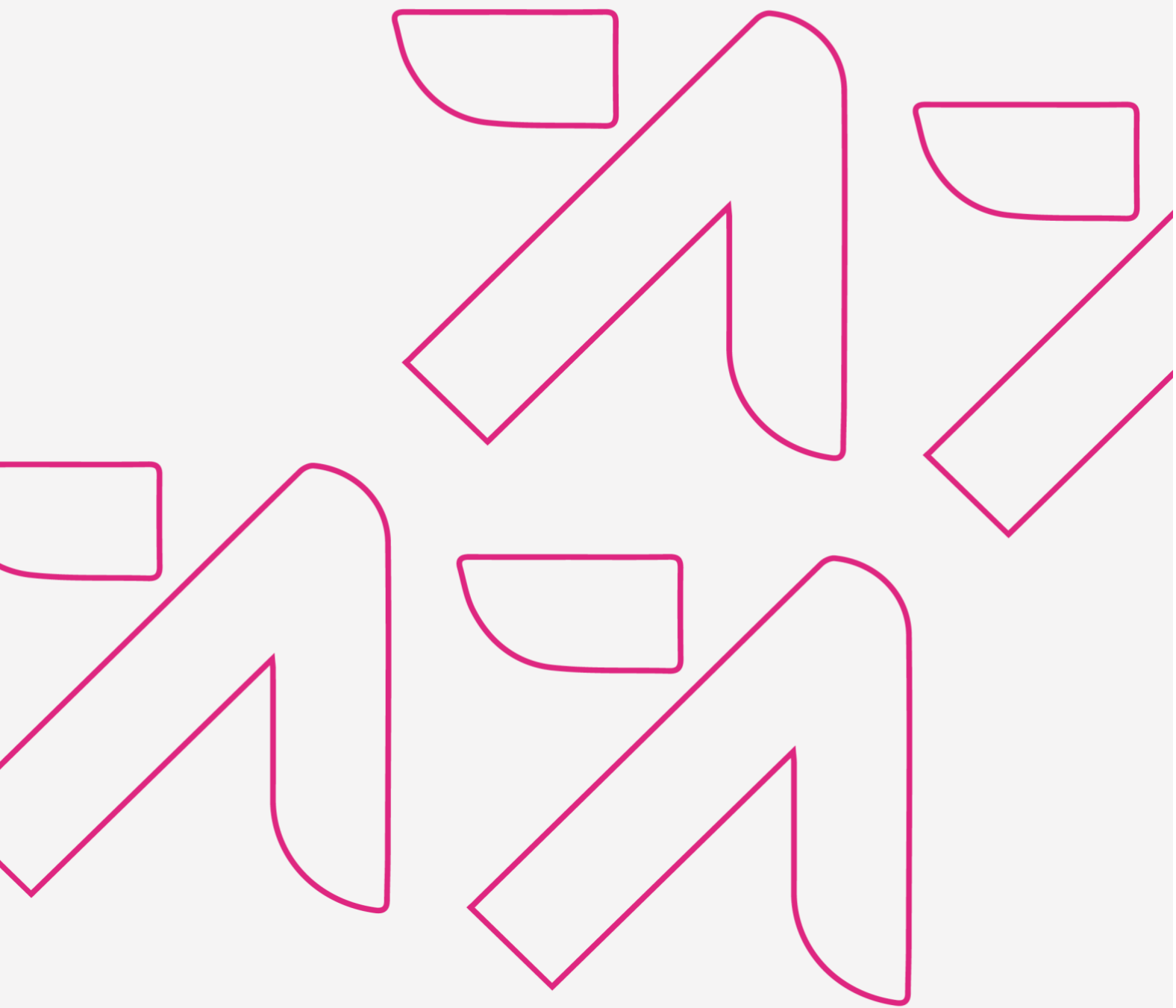




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT2 – Actividad 1. Segmentar una red plana

Encaje en el curso 2026/2027: RA4 · temas 6 y 7 del temario oficial.

1. Enunciado

Una empresa tiene toda su red en un único segmento: puestos de usuario, servidores, impresoras, wifi de invitados y la web pública comparten la misma red. Diseña una **segmentación por zonas** que separe esos elementos según su función y su nivel de confianza.

El objetivo es que entiendas por qué una red plana es peligrosa y cómo se reparte en zonas con sentido.

2. Guía paso a paso

1. Haz la lista de lo que hay conectado: usuarios, servidores internos, servicios públicos, administración, invitados, impresoras e IoT.
2. Agrupa esos elementos en zonas (mínimo 4) y ponle a cada una un nombre que describa su función.
3. Asigna a cada zona una VLAN y un rango de direcciones del tamaño adecuado.
4. Decide qué va en la DMZ y justifica por qué no puede estar en la red interna.
5. Dibuja un diagrama sencillo con las zonas, el firewall y la salida a Internet.
6. Presenta una tabla: Zona / VLAN / Red / Qué contiene / Nivel de confianza.

Reto extra (opcional): añade una zona para teletrabajo y explica si la resolverías con VPN o con acceso de confianza cero (ZTNA), y por qué.

UT2 – Actividad 2. Matriz de flujos y reglas de firewall

1. Enunciado

Sobre la segmentación de la actividad anterior, define la **matriz de flujos permitidos** entre zonas y tradúcela a reglas de firewall con denegación por defecto.

El objetivo es practicar el principio de mínimo privilegio entre segmentos: solo pasa lo que hace falta, y queda escrito por qué.

2. Guía paso a paso

1. Parte de «todo denegado» entre zonas.
2. Enumera las comunicaciones que el negocio necesita de verdad (por ejemplo, web hacia base de datos, usuarios hacia servidor de ficheros).

3. Para cada una, indica origen, destino, puerto, protocolo y motivo.
4. Señala qué flujos deben registrarse en los logs y cuáles no deben existir nunca (por ejemplo, invitados hacia servidores).
5. Revisa que no queda ninguna regla del tipo «cualquier origen, cualquier destino».
6. Entrega la tabla de reglas ordenada, terminando en la regla de denegación general.

Reto extra (opcional): escribe tres de tus reglas en sintaxis real de nftables o de pfSense/OPNsense y explica en qué orden se evalúan.

UT2 – Actividad 3. Contener el movimiento lateral

1. Enunciado

Imagina que un equipo de la red de usuarios queda infectado. Analiza hasta dónde podría llegar el atacante en tu diseño y propón medidas de **microsegmentación y Zero Trust** para contener el movimiento lateral.

El objetivo es comprobar si tu arquitectura aguanta un incidente y documentarla como se haría en un entorno real.

2. Guía paso a paso

1. Sitúa el equipo comprometido en tu diagrama.
2. Recorre tus reglas: ¿a qué otras zonas y servicios puede llegar desde ahí?
3. Identifica los dos caminos más peligrosos (por ejemplo, hacia la red de administración o hacia las copias de seguridad).
4. Propón medidas para cortarlos: aislamiento entre clientes, equipo de salto para administrar, autenticación fuerte, reglas por identidad en lugar de por IP.
5. Actualiza el diagrama y la matriz de flujos con los cambios.
6. Redacta media página explicando qué ha mejorado y qué riesgo queda.

Reto extra (opcional): mapea el recorrido del atacante con técnicas de MITRE ATT&CK (táctica de movimiento lateral) e indica qué control de tu diseño corta cada una.